

华风数据(深圳)有限公司

运维服务信息安全管理制

文档编号	HFSJ-ITSS-0611	版本	V1.0
作者	姚耿桂	编辑日期	2025.1.3
审核	黄剑锋	审核日期	2025.1.3
批准	黄文广	批准日期	2025.1.3
发布范围	内部	发布日期	2025.1.3

文档修订信息

版本号	修订日期	修订人	修订说明	备注
V1.0	2025.1.3	姚耿桂	新增	

目录

1. 目的	5
2. 过程定义	5
2.1. 范围	5
2.2. 过程负责人	5
2.3. 主要输入	5
2.4. 主要输出	6
2.5. 角色和职责权限	6
2.5.1. 运维部经理（信息安全负责人）	6
2.5.2. 运维项目经理（信息安全服务负责人）	6
2.5.3. 运维工程师（信息安全实施人员）	7
2.5.4. 产品质量部	7
2.6. 过程重要控制点	7
3. 术语	7
4. 安全方针	8
5. 流程	8
6. 过程描述	9
6.1. 需求识别和分析	9
6.2. 确定安全实施范围	9
6.3. 信息安全风险评估	9
6.4. 设计安全规范	10
6.5. 实施安全规范	10
6.6. 监控安全状况	11
6.7. 维护安全规范	11
6.8. 信息安全报告	12
7. 相关文件	13
8. KPI指标	13
9. 输出的文件及记录	13

表目录

表 2-1 信息安全输入清单 5

表 2-2 信息安全输出清单 6

表 2-3 信息安全角色职责表 6

表 6-1 信息安全需求识别表 9

表 6-2 安全实施范围确定表 9

表 6-3 风险评估过程表 10

表 6-4 安全规范内容表 10

表 6-5 安全规范实施表 11

表 6-6 安全监控内容表 11

表 6-7 安全规范维护触发条件表 12

表 6-8 信息安全报告内容表 13

表 8-1 KPI指标表 13

表 9-1 输出文件和记录表 13

图目录

图 5-1 信息安全管理流程图 8

1. 目的

本制度旨在对华风数据(深圳)有限公司（以下简称“公司”）执行信息安全风险评估提供指导和规范。

本制度的目的是在运维服务工作中有效管理信息安全：

1. 满足软件产品及项目运行和运维服务中的安全性需求以及合同、法律和外部政策等外部要求；
2. 提供一个满足需求的基本的信息系统安全基线；
3. 确保有效的信息安全措施在管理层、运维服务部门和运维人员三个层面都得到贯彻。

2. 过程定义

安全管理是顺应信息安全的需要而产生的，其主要目标是确保信息的安全性。

安全管理致力于确保服务的安全性在任何时候都能达到与客户约定的级别。

安全性在服务中被视为可用性管理的一部分。安全管理已经成为现代服务管理中一个重要的问题。

安全性是指不易遭到已知风险的侵袭，并且尽可能地规避未知风险的性能。提供这种性能的工具是安全措施。

安全措施的目标是要保护信息的价值，这种价值取决于机密性、完整性和可用性三个方面。

2.1. 范围

本制度适用于运维服务覆盖的所有部门，包括运维部、研发部、产品质量部、综合部。

2.2. 过程负责人

信息安全负责人：运维部经理

2.3. 主要输入

表 2-1 信息安全输入清单

输入	来源
服务级别需求	服务级别协议
配置项、记录和报告	配置管理

2.4. 主要输出

表 2-2信息安全输出清单

输出	去向
风险评估报告	信息安全负责人、部门经理
信息安全管理规范	信息安全负责人、部门经理
变更管理	服务实施过程中，服务交付过程的主要步骤
服务报告管理	服务实施过程中，服务交付过程的主要步骤

2.5. 角色和职责权限

表 2-3信息安全角色职责表

角色	岗位	主要职责
信息安全负责人	运维部经理	负责安全管理制度、流程的建立和维护
信息安全服务负责人	运维项目经理	负责具体项目的安全计划、风险评估和事件处理
信息安全实施人员	运维工程师	负责安全规范的具体实施和执行
质量监督	产品质量部	负责安全过程的审计和改进

2.5.1. 运维部经理（信息安全负责人）

1. 负责本制度的制订、修改与管理；
2. 确定每次信息安全风险评估的范围，组建信息安全风险评估工作组；
3. 负责批准信息安全风险评估报告；
4. 负责整个安全管理流程的有效运作；
5. 监控安全管理流程。

2.5.2. 运维项目经理（信息安全服务负责人）

1. 根据组织安全需求，开发与维护安全计划；

2. 处理与安全相关的问题和事件；
3. 确保满足SLA中指定的安全需求；
4. 负责安排项目中的信息安全风险评估；
5. 做好用户的沟通，协调关于信息安全的问题；
6. 完成包含流程结果、自评估及内部审计的信息安全风险评估报告。

2.5.3. 运维工程师（信息安全实施人员）

1. 按照安全规范执行日常安全操作；
2. 发现安全事件时及时上报；
3. 参与安全风险评估；
4. 保护所负责系统的信息安全。

2.5.4. 产品质量部

1. 对信息安全管理过程进行审计；
2. 监督安全规范的执行情况；
3. 参与安全事件的调查和复盘；
4. 确保管理过程符合ITSS体系要求。

2.6. 过程重要控制点

风险评估报告、信息安全管理规范、安全事件记录。

3. 术语

1. 机密性：指保护信息免受未经授权的访问和使用。
2. 完整性：指信息的准确性、完全性和及时性。
3. 可用性：指信息在任何约定的时间内都可以被访问，这取决于由信息处理系统所提供的持续性。
4. 信息安全风险评估：识别信息资产、评估面临的威胁和脆弱性、确定风险等级的过程。
5. 信息安全管理规范：为保障信息安全而制定的制度、流程和技术措施。

4. 安全方针

遵循公司“统一规划、分级管理、积极防范、人人有责”的原则，按照公司统一部署，结合服务/经营活动的特点，采取一切必要的措施，加强信息安全体系的建设和推进管理。

具体安全方针包括：

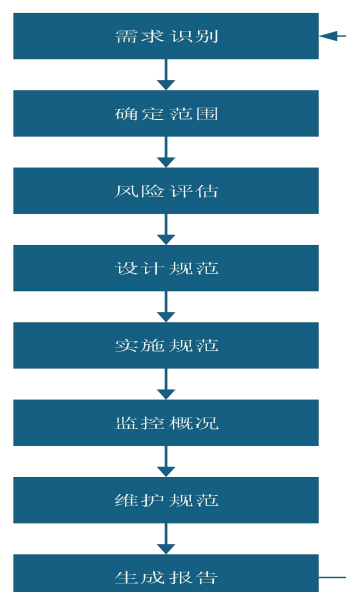
1. 统一规划：由公司统一规划信息安全体系，确保安全策略的一致性和有效性；
2. 分级管理：根据信息资产的重要性，实行分级保护，对不同等级的信息采取不同的安全措施；
3. 积极防范：以预防为主，通过风险评估、安全培训、技术防护等手段，主动防范安全风险；
4. 人人有责：信息安全是全体员工的共同责任，每个员工都应遵守安全规定，保护公司信息资产。

5. 流程

信息安全活动划分为三个部分：规划、实施和监控。

1. 规划：需求识别和分析、确定安全实施范围、信息安全风险评估、安全规范设计
2. 实施：安全规范实施
3. 监控：安全状况监控、维护安全规范、信息安全报告

图 5-1信息安全管理流程图



6. 过程描述

6.1. 需求识别和分析

根据服务级别协议中签订的关于安全的详细说明，确定安全需求并进行分析。

服务级别协议中应该定义安全需求，在可能的情况下还应该以可测度的术语进行定义。该协议的安全部分应当确保客户所有的安全需求和标准能够实现，并且实现的结果能够进行明确的验证。

需求识别的范围包括：

表 6-1信息安全需求识别表

需求类别	说明
人员安全	人员招聘、入职、在岗、离职阶段的安全要求
数据安全	数据分类、数据加密、数据传输、数据存储、数据销毁
机房环境	物理访问控制、环境监控、温湿度控制
设备安全	设备准入、设备使用、设备维护、设备报废
系统安全	系统访问控制、账号管理、补丁管理、日志审计
网络安全	网络隔离、防火墙策略、入侵检测、VPN接入

6.2. 确定安全实施范围

根据安全需求的识别情况确定安全实施范围。安全实施范围包括列为相应安全等级的数据、人员、机房、设备、系统等。

表 6-2安全实施范围确定表

类别	安全等级	实施范围
客户数据	高	所有客户业务数据、配置信息
系统账号	高	服务器、数据库、应用系统账号
公司内部资料	中	制度文档、技术方案、合同
运维工具	中	监控工具、管理软件、脚本
办公设备	低	办公电脑、打印机

6.3. 信息安全风险评估

服务管理人员根据确定的安全实施范围进行风险分析与评估工作，并提交风

险分析与评估报告。

风险评估包括识别安全实施范围内的资产状况、资产面临的威胁、现在使用的技术方法和管理规范，并进行总体分析得出风险的等级，编制《风险评估报告》。

表 6-3风险评估过程表

步骤	活动	输出
1	资产识别	识别需要保护的信息资产、《信息资产清单》
2	威胁识别	识别资产可能面临的威胁、《信息资产脆弱性和威胁表》
3	脆弱性识别	识别资产存在的脆弱性、《信息资产脆弱性和威胁表》
4	风险分析	分析风险发生的可能性和影响程度、《信息资产风险评估表》
5	风险处置	制定风险处置措施、《风险处置计划表》
6	残余风险评估	评估处置后的残余风险、《残余风险报告》

风险评估应至少每年进行一次，或在重大变更、新服务上线时进行。

6.4. 设计安全规范

根据《风险评估报告》，服务负责人制定和编写《信息安全管理规范》。并根据信息安全规范制定信息安全策略、针对个人的保密协议、岗位职责说明等。

表 6-4安全规范内容表

规范类别	规范内容
人员安全规范	岗位职责、保密协议、安全意识培训
访问控制规范	账号管理、权限管理、密码策略
数据安全规范	数据分类、数据加密、数据备份
系统安全规范	系统加固、补丁管理、日志审计
网络安全规范	网络隔离、防火墙策略、VPN接入
物理安全规范	机房出入管理、设备上架、设备报废
应急响应规范	安全事件分级、响应流程、事件上报

6.5. 实施安全规范

在设计好安全规范后，日常需按照安全规范来实施安全管理。

表 6-5安全规范实施表

实施领域	实施内容
人员安全	岗位职责中明确安全责任；新员工入职签订保密协议；定期组织安全培训；员工离职时回收权限
责任划分	关键岗位实行职责分离；重要操作需要双人复核
操作规范	制定书面操作指引；规范系统运维操作流程
开发测试	开发和测试环境与实际运营环境分离；代码安全审查
事件处理	安全事件按《事件管理程序》处理
病毒防护	终端和服务器安装防病毒软件；定期更新病毒库
系统安全	操作系统和应用系统及时更新补丁；关闭不必要的服务和端口
网络安全	网络访问控制；VPN接入认证
数据安全	数据加密传输；敏感数据脱敏使用；数据定期备份
介质安全	存储介质统一管理；废弃介质物理销毁

6.6. 监控安全状况

对安全规范实施进行监控，在工作周报、服务月报中体现。对发生的信息安全事件按照《事件管理程序》执行。

表 6-6安全监控内容表

监控对象	监控内容	监控方式
系统日志	登录日志、操作日志、异常日志	日志审计系统
网络流量	异常流量、非法访问	网络监控系统
病毒防护	病毒查杀情况、病毒库版本	防病毒系统
账号权限	账号变更、权限变更	定期审计
安全事件	安全事件数量和类型	事件管理记录

6.7. 维护安全规范

服务管理人员根据系统运行及运维服务的风险变化，必要时对《信息安全管

理规范》进行修改。

由于基础架构、组织和业务流程方面的变化导致相关的风险也随着发生变化，因此安全也需要进行维护。

安全维护包括服务级别协议中安全部分的维护以及详细的安全规范的维护。

维护需要根据评估的结果以及对风险变化的评估结果进行。这些建议既可以直接被采纳，也可以纳入总体的服务级别协议的维护中。

安全规范更新通过变更管理实施，参照《变更管理程序》。

表 6-7 安全规范维护触发条件表

触发条件	维护内容
新服务上线	评估安全需求，更新安全规范
重大变更	评估安全影响，更新相关规范
安全事件发生	分析事件原因，补充安全措施
风险评估完成	根据风险变化，调整安全策略
法律法规更新	调整合规要求，更新相关规范
客户要求变更	更新SLA安全部分，调整规范

6.8. 信息安全报告

信息安全管理负责人根据信息安全管理实施状况及日常发生的安全事件等，每月进行一次巡检，编写《信息安全服务报告》。

报告可以提供有关已实现安全绩效方面的信息，并可以了解有关的安全问题。

正确地了解有关努力（如安全措施的实施）所取得的效率以及实际被采用的安全措施。

还需要了解所有的安全事件。为报告服务级别协议中定义的安全事件，可通过服务级别管理负责人、事件管理负责人或安全管理负责人与部门经理直接的沟通渠道。

除了在特殊情形下的例外事项，报告都是通过服务级别管理负责人进行传达的。

根据信息安全管理需要报告信息安全的实施情况，并提交给《服务报告》中。

表 6-8信息安全报告内容表

报告要素	内容说明
安全指标完成情况	KPI指标完成情况统计
安全事件统计	安全事件数量、类型、处理情况
安全检查结果	巡检发现的问题、整改情况
风险评估更新	风险变化情况、新识别风险
安全改进措施	已实施的改进措施、效果验证
安全计划	下阶段安全工作重点

7. 相关文件

1. 《服务报告管理程序》
2. 《事件管理程序》
3. 《变更管理程序》
4. 《配置管理程序》

8. KPI指标

表 8-1 KPI指标表

指标名称	指标计算方式	目标值	考核频次
安全培训覆盖率	(接受培训人数/应培训人数)×100%	≥95%	年度
信息安全事故数量	我方人员造成安全事故的次数	≤1次	年度

9. 输出的文件及记录

表 9-1 输出文件和记录表

文件及记录	责任部门
《信息资产清单》	运维部
《信息资产脆弱性和威胁表》	运维部
《信息资产风险评估表》	运维部
《风险处置计划表》	运维部

文件及记录	责任部门
《残余风险报告》	运维部
《信息安全管理规范》	运维部
《信息安全服务报告》	运维部